

CYBERSECURITY GOVERNANCE, RISK, AND COMPLIANCE

Executive GRC Assessment Report

Trainory fitness and wellness technology platform

Prepared for: Executive leadership and portfolio reviewers

Prepared by: Jared Sanchez | GRC Portfolio Project

Reporting period: 2026 baseline assessment (fictional scenario)

Framework: NIST Cybersecurity Framework 2.0

Classification: Portfolio Demonstration | Fictional Data

Executive recommendation: Continue controlled operation while aggressively remediating high residual risks. Approve the VitaSync integration only conditionally, remove inappropriate access immediately, and require evidence that critical controls are operating before risk is accepted.

Purpose

Translate detailed GRC artifacts into a concise, decision-oriented view of Trainory's cyber risk posture, control maturity, assurance gaps, and remediation priorities.

1. Executive Summary

Trainory's baseline security posture is developing. The assessment found useful foundational practices, but many controls are only partially implemented or lack operating evidence. Existing controls reduce aggregate modeled risk by approximately 28%; however, 11 of 15 identified risks remain High after considering those controls.

RESIDUAL EXPOSURE	CSF MATURITY	ACCESS EXCEPTIONS	OPEN FINDINGS
11 <i>High risks</i>	50% <i>22 outcomes assessed</i>	11 <i>of 28 records</i>	14 <i>access + vendor</i>

Leadership decision

Decision: Treat the current posture as elevated but manageable. Maintain service with documented guardrails, prioritize the highest-impact corrective actions, and require owners to provide closure evidence rather than reporting completion without validation.

Primary conclusions

- Identity and access weaknesses create immediate exposure, including a terminated contractor account, unnecessary production/database access, and an unowned privileged service account.
- Application, cloud, monitoring, and recovery controls require formal baselines, recurring testing, and evidence of consistent operation.
- VitaSync's 70% control score supports conditional, not unconditional, approval because all six formal vendor findings remain material.
- The NIST CSF assessment reflects a baseline maturity score of 50%; policy documents created during this portfolio do not count as fully implemented controls until approved, communicated, tested, and evidenced.

Immediate management actions

1. Disable and investigate the terminated contractor account; preserve the offboarding and activity-review evidence.
2. Remove direct production/database access that is not required and replace broad roles with least-privilege alternatives.
3. Place VitaSync under conditional approval and establish monthly remediation reporting with owners, due dates, closure evidence, and defined risk-acceptance authority.

2. Scope and Methodology

The assessment examined a fictional cloud-based fitness and wellness platform that stores customer profiles, workout history, performance information, account data, and data imported from wearable devices. The review focused on the systems and processes most likely to affect confidentiality, integrity, availability, privacy, and customer trust.

Assessment scope

- 15 business, technology, data, security, and third-party assets.
- 15 cybersecurity and privacy risk scenarios scored using a 5 x 5 likelihood-impact method.
- 22 selected NIST CSF 2.0 outcomes across Govern, Identify, Protect, Detect, Respond, and Recover.
- A 25-question security and privacy review of VitaSync, a fictional wearable-data integration vendor.
- A quarterly certification of 28 workforce, contractor, vendor, and service-account access records.

Method

Step	Activity	Purpose
1	Establish scope	Identify critical assets, owners, data sensitivity, dependencies, and business impact.
2	Assess risk	Score inherent likelihood and impact, evaluate existing controls, then record residual risk.
3	Evaluate controls	Map expected outcomes to NIST CSF 2.0 and review assumed evidence, status, gaps, and ownership.
4	Test assurance	Review vendor responses and user access; convert significant exceptions into formal findings.
5	Prioritize action	Assign treatment, owner, target date, required evidence, and residual-risk rationale.
6	Report decisions	Summarize exposure and recommendations in metrics, dashboards, and this executive report.

Scoring model

Risk score = Likelihood (1-5) x Impact (1-5). Scores of 1-4 are Low, 5-9 Moderate, 10-16 High, and 17-25 Critical. Residual risk represents the exposure remaining after considering current controls. Ratings support, but do not replace, risk-owner and leadership judgment.

Assessment limitation: All content and evidence are fictional. Policy creation shows design intent; implementation must be demonstrated through approval, testing, records, and recurring review.

3. Enterprise Risk Posture

No risks remained Critical after existing controls were considered, but the portfolio is still concentrated in High residual exposure. This means Trainory has useful safeguards, yet the safeguards are not strong or mature enough to reduce most material scenarios to Moderate or Low.

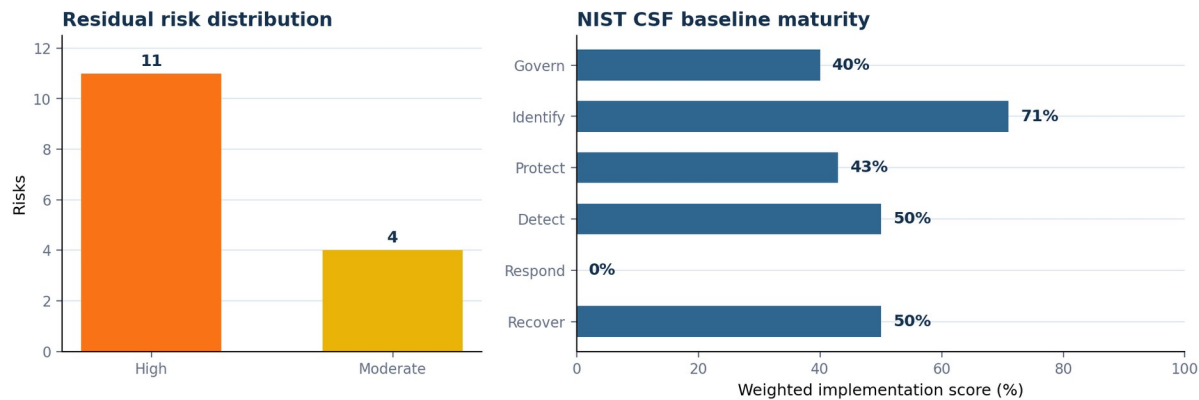


Figure 1. Residual-risk concentration and NIST CSF baseline maturity.

Highest-priority enterprise risks

Risk	Scenario	Residual	Priority treatment
TRN-R001	Account compromise	15 / High	Customer MFA, credential screening, rate limiting, stronger alerting
TRN-R006	Unpatched application vulnerability	15 / High	Automated scanning and severity-based remediation deadlines
TRN-R003	Excessive privileged access	12 / High	Least-privilege roles, approvals, quarterly reviews, monitoring
TRN-R011	Backup restoration failure	12 / High	Recovery objectives, isolated backups, quarterly restoration tests
TRN-R012	Insufficient security monitoring	12 / High	Centralized logs, defined alerts, ownership, escalation testing
TRN-R013	Inadequate privacy and consent	12 / High	Data inventory, consent evidence, retention and deletion workflow

Risk treatment position

The dominant treatment is mitigation. Transfer applies selectively to third-party services, while monitoring is appropriate only when residual exposure, ownership, escalation thresholds, and contingency measures are clearly documented. High risks should not be silently accepted by operational teams; acceptance authority should be defined and recorded.

4. Control Maturity and NIST CSF Alignment

The baseline assessment reviewed 22 selected NIST CSF 2.0 outcomes. Three were Implemented, 16 were Partial, and three were Not Implemented, producing a weighted maturity score of 50%. Identify is the strongest function because Trainory established asset and risk records; Respond is the weakest because an approved and exercised process was not evidenced at the time of assessment.

Function	Outcomes	Maturity	Management focus
Govern	5	40%	Formalize risk appetite, responsibility, policy governance, and vendor requirements.
Identify	7	71%	Validate inventories and make threat, vulnerability, and risk reviews recurring.
Protect	7	43%	Strengthen access lifecycle, secure configurations, patching, data protection, and awareness.
Detect	1	50%	Expand centralized monitoring and document alert ownership and escalation.
Respond	1	0%	Approve the incident plan, train roles, and conduct a credential-compromise exercise.
Recover	1	50%	Define recovery objectives and test restoration and communications quarterly.

Design versus operating effectiveness

Important distinction: The Access Control Policy and Incident Response Plan improve Trainory's documented control design. They should not automatically change a control to Implemented. Operating effectiveness requires approval, communication, assigned ownership, consistent execution, testing, and retained evidence over time.

Evidence needed to demonstrate progress

- Policy approvals, employee acknowledgments, role assignments, and exception records.
- Completed quarterly access certifications and verified remediation tickets.
- Vulnerability, patch, configuration, logging, and alert-review reports tied to defined service levels.
- Incident exercise records, lessons learned, backup restoration results, and recovery-objective performance.
- Vendor assurance reports, contract clauses, subprocessor records, and evidence that findings were closed or accepted.

5. Assurance Results

Quarterly access review

The review examined 28 access records across Microsoft 365, GitHub, AWS, customer data, support, analytics, and payment systems. Seventeen records were retained; three required modification, five removal, and three escalation. Eleven exceptions produced eight formal findings: four Critical and four High.

Response	Finding	Required evidence
Terminate	Former contractor retained AWS access	Disable, revoke sessions, review activity, preserve evidence
Restrict	Developer and support roles exceeded job needs	Remove direct database access and broad administrator roles
Govern	Privileged service account lacked an owner	Assign ownership, rotate credentials, document scope and review date
Time-limit	Vendor repository access lacked expiration	Record sponsor, scope, expiration, and quarterly validation
Correct mover	Marketing employee retained support access	Remove inherited access and examine the transfer process

VitaSync third-party assessment

VitaSync received an overall weighted control score of approximately 70%. The recommended decision is Conditional Approval because six material findings remain: three Critical and three High. Trainory should restrict scope and production exposure until the most consequential assurance and contractual gaps are resolved.

Condition	Rating	Required action
Independent assurance	High	Obtain current SOC 2 Type II or equivalent assurance.
Incident notification	Critical	Require notice without undue delay and within 24 hours of confirmed Trainory impact.
Disaster recovery	Critical	Review current DR test results before production approval.
Retention and deletion	Critical	Define retention, backup deletion, completion timing, and written confirmation.
Privileged access	High	Require quarterly review evidence for privileged roles.
Subprocessor obligations	High	Confirm security, notification, audit-cooperation, and termination rights.
Approval boundary: Conditional approval permits only a limited, monitored integration with restricted API scopes, separate credentials, contract conditions, and tracked remediation. It is not a statement that the vendor is fully compliant or risk-free.		

6. Remediation Roadmap

The roadmap sequences urgent exposure reduction before broader program maturity work. Dates and sequencing should be adjusted by accountable owners after technical validation, resource review, and executive approval.

Timing	Objective	Actions	Accountability
0-30 days	Contain immediate exposure	Disable terminated access; remove unnecessary production/database privileges; assign the service-account owner; preserve closure evidence.	Cybersecurity, IT, system owners
0-30 days	Set governance	Approve risk appetite, acceptance authority, control ownership, and a monthly remediation review.	Executive leadership, Compliance
31-60 days	Strengthen vendor conditions	Resolve incident-notification, DR evidence, retention/deletion, assurance, and subprocessor requirements.	Vendor Management, Privacy/Legal
31-60 days	Improve protection	Implement secure configuration baselines, vulnerability scanning, patch SLAs, least-privilege roles, and customer-account safeguards.	Cloud, Development, Cybersecurity
61-90 days	Validate response and recovery	Conduct an incident tabletop and restoration test; record lessons, exceptions, and corrective actions.	Incident team, Cloud, Communications
61-90 days	Measure operating effectiveness	Collect recurring evidence, retest closed findings, update residual risk, and report trend metrics.	GRC, control owners, Internal Audit

Recommended governance cadence

Cadence	Review	Participants
Monthly	High-risk remediation and overdue finding review	Risk owners and executive sponsor
Quarterly	Risk register refresh, access certification, vulnerability and recovery metrics	GRC and control owners
Annually	Policy approval, vendor reassessment, NIST CSF maturity review, incident exercise	Executive leadership and GRC
Event-driven	Material incident, major architecture change, new sensitive-data use, or vendor change	Relevant owner with GRC review

Success measures

- Reduce High residual risks from 11 to a management-approved target after evidence-based reassessment.
- Close all Critical access and vendor findings or document formal acceptance by authorized leadership.
- Raise the selected NIST CSF maturity score through verified implementation, not documentation alone.
- Complete access reviews, incident exercises, and restoration tests on schedule with retained evidence.

7. Management Conclusion

Trainory has established the essential building blocks of a GRC program: an asset inventory, risk register, control assessment, policy and response documentation, vendor due diligence, access certification, analytics dashboard, and a Python reporting utility. Together, these artifacts create a traceable path from business assets to risks, controls, evidence, findings, remediation, and management decisions.

The current assessment does not support declaring the environment mature or fully compliant. The defensible conclusion is that risk is elevated but can be managed through immediate access correction, disciplined vendor conditions, stronger technical controls, tested response and recovery, and recurring evidence-based oversight.

Recommended disposition: Approve continued controlled operation and limited conditional vendor integration, subject to the 90-day roadmap, monthly executive review, closure validation, and formal acceptance of any residual risk that remains above tolerance.

Evidence and portfolio artifacts

Step	Artifact	Evidence demonstrated
1	Company Profile and Scope	Business context, system boundary, stakeholders, assumptions
2	Asset Inventory	Assets, ownership, sensitivity, criticality, third-party dependencies
3	Cybersecurity Risk Register	Inherent/residual scoring, treatment, ownership, actions
4	NIST CSF 2.0 Assessment	Control status, evidence, gaps, priorities, framework mapping
5	Access Control Policy	Identity lifecycle, least privilege, reviews, exceptions
6	Incident Response Plan	Roles, severity, lifecycle, communications, exercises
7	Third-Party Vendor Risk Assessment	VitaSync due diligence, findings, conditional decision
8	Quarterly Access Review	Certification decisions, evidence log, corrective actions
9	GRC Analytics Dashboard	Formula-driven KPIs, charts, normalized source data
10	Python Risk Scoring Tool	CSV validation, scoring, prioritization, automated reporting, tests

Framework reference

National Institute of Standards and Technology, *Cybersecurity Framework 2.0*:
<https://www.nist.gov/cyberframework>

Portfolio disclaimer: Trainory, VitaSync, all people, systems, risk ratings, evidence, findings, dates, and decisions in this report are fictional and created for educational portfolio purposes. This report is not an audit opinion, certification, legal conclusion, or production authorization.